

인적보안 지침



주식회사 모인

개정 이력

[illegible]

인적보안지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 “회사라 한다)의 인적 요인에 의해 발생할 수 있는 정보의 유출, 변조, 오남용, 삭제 등 각종 보안 위험을 최소화 시키기 위한 보안 관리 기준의 규정을 목적으로 한다.

제2조(적용 범위) 이 지침은 회사의 모든 임직원, 임시직원 및 외부직원을 포함한 회사 내 모든 자를 대상으로 한다.

제3조(용어의 정의) 이 지침은 다음 용어 정의를 따른다.

- 1 “개인정보 담당”이란 고객의 개인정보를 수집, 보관, 처리, 이용, 제공, 관리 또는 파기 등의 업무를 하는 임직원 및 외부직원을 의미한다.
- 2 “시스템 개발 담당”이란 소프트웨어 및 정보처리시스템을 설계·개발·개선하며, 신규 기능 구현과 유지보수, 소스코드 작성 및 변경하고 프로그램을 개발하는 자를 말한다.
- 3 “시스템 운영 담당”이란 정보처리시스템과 인프라를 안정적으로 운영·관리하기 위하여 배포, 백업, 모니터링, 장애 대응 및 접근권한 관리 등의 업무를 수행하는 자를 말한다.
- 4 “정보보호 담당”이란 조직의 정보보호 체계 전반을 총괄·관리하며, 정보자산의 기밀성·무결성·가용성을 보장하기 위한 정책 수립, 보안 통제 운영, 위험 관리 및 사고 대응 등의 업무를 수행하는 자를 말한다.
- 5 “전산자료”란 전산장비에 의해 입력·보관·출력되어 있는 자료를 말하며 그 자료가 입력·출력되어 있는 자기테이프, 디스크 등의 보조기억매체를 포함한다.
- 6 “정보시스템”이란 정보통신기술을 이용할 수 있는 근간이 되는 시스템으로, 서버 시스템, 네트워크 장비, DBMS, 정보보호시스템 등을 의미한다.
- 7 “정보처리시스템”이란 전자금융업무를 포함하여 정보기술부문에 사용되는 하드웨어(hardware)와 소프트웨어(software)를 의미하며, 관련 장비를 포함한다.
- 8 “정보기술부문”이란 컴퓨터 등 정보처리능력을 가진 장치를 이용하여 정보를 수집·가공·저장·검색·송신 또는 수신을 행하는 회사의 업무, 인력, 시설 및 조직을 의미한다.
- 9 “개인정보처리시스템”이란 개인정보를 처리할 수 있도록 체계적으로 구성한 데이터베이스시스템 등을 의미한다

제2장 인력 보안관리

제4조(입사 시 보안관리) 인사팀은 정보보안 인력, 개인(신용)정보 취급자 등 중요하고 민감한 정보를 취급하는 인력 채용시 입사 전에 대상자들에 대한 경력 검증 및 업무 수행에 필요한 자격 조건(학력, 경력, 자격증 등)의 기준을 마련하여 채용 시 적합성을 확인하여야 한다.

제5조(보안서약서 징구 및 관리)

- 1 회사의 모든 임직원은 입사 시 정보보호 및 개인(신용)정보보호의 필요성과 책임, 내부 정책 및 관련 법규 준수, 퇴사 이후의 비밀 유지 의무에 대해 명시된 보안서약서에 서명을 하여야 한다.
- 2 보안서약서는 업무별로 필요한 내용을 각각 다르게 작성하여 징구 할 수 있다.
- 3 보안서약서는 비인가자의 접근을 통제하여 안전하게 보관하고, 필요 시 쉽게 찾아볼 수 있도록 관리하여야 한다.

제6조(퇴사 및 직무변경시 보안관리)

- 1 회사는 임직원의 퇴직 및 직무변경 등 인사 변경 내용이 인사팀, 정보보안팀(이하 “보안팀”) 등 관련 부서 간에 신속히 공유될 수 있도록 절차를 수립 및 이행하여야 한다.
- 2 회사는 임직원의 퇴사 및 직무 변경 시 업무 필요성이 존재하지 않는 내부 정보처리시스템에 접근할 수 없도록 정보자산 반납, 접근권한 회수 및 조정, 계정 삭제 또는 잠금 등의 절차를 수행하여야 한다.
- 3 보안팀은 임직원의 퇴사 또는 직무가 변경된 경우 및 관련 외부자가 공유 계정을 사용했을 경우에는 해당 계정의 비밀번호를 즉시 변경하고, 변경된 기록을 보존하여야 한다.
- 4 보안팀은 퇴직 절차 준수 여부에 대하여 정기적으로 검토하여야 한다.

제7조(외부자 보안관리) 외부자 보안 관리에 관한 사항은 「외부주문 보안 지침」을 따른다.

제3장 직무분리

제8조(직무 분리 기준)

- 1 회사는 전자금융거래의 안전성 확보 및 이용자 보호를 위해 다음 각 호의 업무에 대하여 직무를 분리하여 운영하여야 한다. 이 경우 정보보호위원회는 직무분리의 원칙에 따라 다음 각 호의 업무담당자를 지정한다.
 - 1) 개인정보 담당 직무
 - a) 개인정보 보호책임자(CPO)와 개인정보취급자(개인정보 처리 실무자)의 역할을 분리한다.
 - 2) 시스템 개발 담당 직무

- a) 시스템 개발관리자와 시스템 개발자의 역할과 책임을 분리하며, 응용 개발과 시스템 개발 업무도 별도 담당자가 수행하도록 한다.
 - 3) 시스템 운영 담당 직무
 - a) 시스템 운영관리자, 시스템 운영자, 암호화키 관리 담당자는 역할과 책임을 분리하여 운영하며, 시스템 운영 직무는 시스템 개발 직무와 역할을 상호분리한다.
 - 4) 정보보호 담당 직무
 - a) 정보보호최고책임자(CISO), 정보보호 관리자, 정보보호 담당자, 보안관제 담당자, 정보보안 감사인, 물리보안담당자의 역할을 분리한다.
 - b) 정보보호 직무는 시스템 운영 직무 및 시스템 개발 직무와 독립적으로 수행한다.
 - c) 내부감사자는 운영, 개발, 정보보호 직무와 독립적으로 수행되도록 직무를 분리한다.
 - 5) 내부인력과 외부인력의 구분
 - a) 개인정보 및 정보시스템을 처리하는 내부인력과 위탁·용역 등 외부 인력은 상호 분리하여 관리하며, 외부 인력은 내부 인력의 감독 하에 업무를 수행한다.
 - 6) 그 밖에 내부통제와 관련하여 직무의 분리가 요구되는 경우
- 2 회사는 불가피하게 직무 분리가 어려운 경우에는 권한 남용이 발생하지 않도록 감사로그 유지를 통한 책임추적성 확보 및 직무수행 모니터링 등 보완 통제를 수립하여 운영하여야 한다.

제4장 보안 준수

제9조(보안 의무 위반 금지)

- 1 회사의 모든 임직원과 관련 외부자는 법령과 규제 및 내부 보안정책에 따른 정보보호 및 개인(신용)정보보호 책임과 의무에 위반하는 행위를 하여서는 아니 된다.
- 2 회사의 모든 임직원은 최소한 연 1회 사용자수칙과 보안정책을 읽고 이해하였음을 확인하고, 이를 성실하게 준수할 것을 서약하는 자필서명을 하여야 한다

제10조(보안 의무 위반 시 제재)

- 1 회사는 임직원이 법령과 규제 및 내부정책에 따른 정보보호 및 개인(신용)정보보호 책임과 의무를 위반한 경우 다음 절차에 따라 제재하여야 한다.
 - 1) 임직원은 정보보호 관련법규 위반 사실을 알게 되면, 이를 보안팀에 알린다.
 - 2) 정보보호최고책임자(이하 “CISO”라 한다)는 관련 사실에 대한 조사결과와 위반자로부터의 소명결과를 정보보호위원회에 보고한다.
 - 3) 정보보호위원회는 구두경고, 서면경고, 감봉, 정직, 해고 중 제재의 수준을 정하고, 참석자 과반수의 찬성으로 이를 결정한다.
- 2 위반 사항은 필요 시 회사 내부에 전사 공지 또는 교육 사례로 활용한다.

제5장 정보보호 및 개인(신용)정보보호 교육

제11조(연간 계획 수립)

- 1 보안팀은 모든 임직원, 임시직원 및 관련 외부자 등의 보안 인식 제고를 위해 교육 목적, 교육 대상, 교육 내용, 교육일정 및 방법 등을 포함하는 연간 정보보호 및 개인(신용)정보보호 교육 계획을 수립하여야 한다.
- 2 보안팀은 교육 계획 시 임직원의 역할 및 직무 별로 요구되는 최소 이수교육시간을 고려하여 수립·운영하여야 하며, 최소 이수 시간은 다음 각 호와 같다.
 - 1)임원: 3시간 이상 (다만, CISO는 6시간 이상)
 - 2)일반직원: 6시간 이상
 - 3)정보기술부문업무 담당 직원: 9시간 이상
 - 4)정보보호업무 담당 직원: 12시간 이상
- 3 보안팀은 교육 프로그램 개발의 경우 정보보호 전문 교육기관에 위탁할 수 있다.
- 4 보안팀의 연간 교육계획은 CISO의 승인을 득하여야 한다.

제12조(교육 대상 및 내용)

- 1 정보보호 및 개인(신용)정보보호 관련 교육은 조직의 관리체계와 정책을 이해하고 이를 준수할 수 있도록 다음 각 호와 같은 내용을 포함할 수 있다.
 - 1)정보보호 및 개인(신용)정보보호의 기본 개요, 관리체계 구축 및 방법, 관련 법률
 - 2)정보보호 및 개인(신용)정보보호 관련 내규, 관리적·기술적·물리적 조치사항
 - 3)중요정보 및 개인(신용)정보 침해(유출)사고 사례 및 대응방안, 규정 위반 시 법적 책임 등
- 2 보안팀은 신규 입사자를 대상으로 조직 정책, 주의해야 할 사항, 규정 위반 시 법적 책임 등에 대한 내용 숙지할 수 있도록 업무 시작 전 정보보호 및 개인(신용)정보보호 교육을 실시하여야 한다.
- 3 보안팀은 모든 임직원을 대상으로 정보보호를 생활화하고, 개인(신용)정보의 적정한 취급을 보장하며, 조직의 정보 관련 관리체계와 정책을 이해하고 준수할 수 있도록 정보보호교육과 개인(신용)정보보호 교육을 연1회 이상 실시하여야 한다.
- 4 회사는 정보기술 및 정보보호 조직 내 임직원을 대상으로 정보보호 및 개인(신용)정보보호와 관련하여 직무 별 전문성 제고를 위해 별도 교육을 실시하거나 지원하여야 한다.

제13조(교육의 이행)

- 1 교육은 집합 교육 이외에 인터넷 교육, 이메일 등 다양한 방법을 활용할 수 있으며, 필요에 따라 전문기관이나 전문요원에 위탁하여 실시할 수 있다.
- 2 보안팀은 조직 내·외부 침해사고 발생, 정보보호 관련 법규 변경 및 조직 내 정보보호 및

개인(신용)정보보호 관련 정책의 중대한 변화가 발생할 경우에는 추가적인 교육을 수행하여야 한다.

- 3 보안팀은 출장, 휴가 등의 사정으로 정기 정보보호 및 개인(신용)정보보호 교육을 받지 못한 인력에 대해서는 전달교육, 추가교육, 온라인교육, 서면 교육 등의 방법으로 정보보호 교육을 시행하여야 한다.

제14조(교육 사후 관리)

- 1 보안팀은 교육 완료 후 교육 참석여부를 기록 및 관리하고 교육대상, 일시, 장소, 내용, 참석 대상 등이 포함된 교육결과 보고서를 작성하여 보관한다.
- 2 CISO는 정보보호교육을 실시한 이후 대상 임직원에게 대해 평가를 실시하고, 결과는 차기 교육 계획 수립에 활용한다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.